



Weekly IT Security Brief (Official-source-first) | 2026-08-09 06:00

Formatted for readability · Auto-generated



Weekly Summary

- Priority snapshot: 5 KEV-listed vulnerabilities are actively exploited in the wild (top 8 shown in this brief).
- Urgent patch focus: CVE-2026-8037(2026-08-10), CVE-2026-63077(2026-08-08), CVE-2026-18556(2026-08-07). Prioritize internet-facing and privileged systems first.
- Threat trend #1: Microsoft named a Leader in the KuppingerCole Leadership Compass for Cloud Native Application Protection Platforms (CNAPP). Learn why KuppingerCole named Microsoft a Leader in its Leadership Compass: Cloud Native Application Protection Plat...
- Threat trend #2: From open lures to cloaked gates: How a macOS ClickFix campaign learned to hide. A macOS ClickFix campaign shifted tactics from openly serving infostealer lures to hiding them behind a browser-fingerprinting gate. The change makes malicious i...
- Recommended action this week: patch KEV/high-risk exposed services within 24 hours and tighten monitoring for anomalous login, command execution, and credential access patterns.



Report A: CVE Deep Dive (CISA KEV + NVD)

CVE-2026-8037

CVE Title	CVE-2026-8037 progress/connection_manager_for_objectscale Remote Code Execution
CVE Description	OS Command Injection Remote Code Execution Vulnerability in API in Progress ADC Products allows an un-authenticated attacker to execute arbitrary commands on the LoadMaster appliance by exploiting unsanitized input in multiple command endpoints
Root Cause	Unsafe deserialization or input-handling flaws enable arbitrary code execution.
Exploitation Prerequisite	Relevant endpoint is exposed and unpatched.
Exploit Path	Malicious request/payload -> vulnerability trigger -> remote command execution.
Affected Products	progress/connection_manager_for_objectscale, progress/ecs_connection_manager, progress/loadmaster
Risk Score	9.6 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-08-10
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-8037

CVE-2026-63077

CVE Title	CVE-2026-63077 jetbrains/teamcity Remote Code Execution
CVE Description	In JetBrains TeamCity before 2026.1.3, 2025.11.7 unauthenticated remote code execution was possible via the agent polling protocol
Root Cause	Unsafe deserialization or input-handling flaws enable arbitrary code execution.
Exploitation Prerequisite	Relevant endpoint is exposed and unpatched.
Exploit Path	Malicious request/payload -> vulnerability trigger -> remote command execution.
Affected Products	jetbrains/teamcity
Risk Score	9.8 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-08-08
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-63077

CVE-2026-18556

CVE Title	CVE-2026-18556 n-able/n-central Auth Bypass
CVE Description	Authentication bypass using an alternate path or channel vulnerability in N-able N-central allows Authentication Bypass.
Root Cause	Authentication workflow has logical flaws allowing bypass.
Exploitation Prerequisite	Target service is network-reachable and accepts attacker-crafted unauthorized requests.
Exploit Path	Unauthorized request -> auth bypass -> sensitive data access / privileged operations.
Affected Products	n-able/n-central
Risk Score	7.4 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-08-07
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-18556

CVE-2026-34486

CVE Title	CVE-2026-34486 apache/tomcat Unknown Type
CVE Description	Missing Encryption of Sensitive Data vulnerability in Apache Tomcat due to the fix for CVE-2026-29146 allowing the bypass of the EncryptInterceptor.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	apache/tomcat, redhat/jboss_web_server, redhat/enterprise_linux, redhat/enterprise_linux_els, redhat/enterprise_linux_eus
Risk Score	7.5 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-08-07
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-34486

CVE-2026-9198

CVE Title	CVE-2026-9198 langflow/langflow Unknown Type
CVE Description	IBM Langflow OSS 1.0.0 through 1.10.0 allows unauthenticated attackers to chain /api/v1/auto_login (mints SUPERUSER tokens to any network caller) with /api/v1/validate/code (executes user code via exec()) to achieve full RCE on default Langflow deployments
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	langflow/langflow
Risk Score	9.8 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-08-07
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-9198

Report A2: Newly Published CVEs (NVD, last 7 days)

CVE-2026-17002

CVE Title	CVE-2026-17002 待核實 Unknown Type
CVE Description	Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
Affected Products	待核實
Risk Score	待核實 (待核實)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-17002

CVE-2026-13339

CVE Title	CVE-2026-13339 待核實 Unknown Type
CVE Description	The CubeWP Framework plugin for WordPress is vulnerable to Directory Traversal in all versions up to, and including, 1.1.30 via the 'cubewp_get_svg_content' function. This makes it possible for unauthenticated attackers to read the contents of arbitrary files on the server, which can contain sensitive information. This is exploitable by unauthenticated attackers because the required nonce is publicly emitt...
Affected Products	待核實
Risk Score	7.5 (HIGH)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-13339

CVE-2026-18352

CVE Title CVE-2026-18352 | 待核實 | Unknown Type

CVE Description The User Access Manager plugin for WordPress is vulnerable to Directory Traversal in all versions up to, and including, 2.3.15 via the 'uamgetfile' parameter parameter. This makes it possible for unauthenticated attackers to read the contents of arbitrary files on the server, which can contain sensitive information. This is possible because when attachment_url_to_postid() returns 0 for a traversal path, th...

Affected Products 待核實

Risk Score 7.5 (HIGH)

Source <https://nvd.nist.gov/vuln/detail/CVE-2026-18352>

CVE-2026-8457

CVE Title CVE-2026-8457 | 待核實 | Auth Bypass

CVE Description The WooCommerce - Social Login plugin for WordPress is vulnerable to Authentication Bypass in all versions up to and including 2.8.7. This is due to the plugin's Apple login handler accepting the Apple id_token and decoding only its base64 payload without verifying the JWT signature against Apple's public keys or validating the issuer, audience, or expiry claims, combined with the security nonce required t...

Affected Products 待核實

Risk Score 9.8 (CRITICAL)

Source <https://nvd.nist.gov/vuln/detail/CVE-2026-8457>



Report B: Threat Intelligence News (last 7 days)

Headline: Microsoft named a Leader in the KuppingerCole Leadership Compass for Cloud Native Application Protection Platforms (CNAPP)

Source	Microsoft Security Blog
Published	Wed, 05 Aug 2026 16:30:00 +0000
Key Takeaway	Learn why KuppingerCole named Microsoft a Leader in its Leadership Compass: Cloud Native Application Protection Platforms report. The post Microsoft named a Leader in the KuppingerCole Leadership Compass for Cloud Native Application Protection Platforms (CNAPP) appeared first on Microsoft Security Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral mov...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	cloud/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.microsoft.com/en-us/security/blog/2026/08/05/microsoft-named-a-leader-in-the-kuppingercole-leadership-compass-for-cloud-native-application-protection-platforms-cnapp/

Headline: From open lures to cloaked gates: How a macOS ClickFix campaign learned to hide

Source	Microsoft Security Blog
Published	Wed, 05 Aug 2026 15:48:39 +0000
Key Takeaway	A macOS ClickFix campaign shifted tactics from openly serving infostealer lures to hiding them behind a browser-fingerprinting gate. The change makes malicious infrastructure harder to detect while giving defenders new hunting opportunities. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ics/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.microsoft.com/en-us/security/blog/2026/08/05/macOS-clickfix-campaign-learned-hide/

Headline: CISA Guide Helps Federal Agencies Securely and Effectively Use Open Source Software

Source CISA News

Published Thu, 30 Jul 26 12:00:00 +0000

Key Takeaway CISA Guide Helps Federal Agencies Securely and Effectively Use Open Source Software Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.

Summary Engine extractive-rules

Threat Actors Not explicitly stated

Target unknown-target

Technique 待核實

MITRE ATT&CK Unverified

Related CVEs None

Link <https://www.cisa.gov/news-events/news/cisa-guide-helps-federal-agencies-securely-and-effectively-use-open-source-software>

Headline: CISA and Partners Unveil Updated Software Bill of Materials Resource That Improves Transparency, Security and Risk-Informed Decision Making

Source	CISA News
Published	Wed, 29 Jul 26 12:00:00 +0000
Key Takeaway	CISA and Partners Unveil Updated Software Bill of Materials Resource That Improves Transparency, Security and Risk-Informed Decision Making Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.cisa.gov/news-events/news/cisa-and-partners-unveil-updated-software-bill-materials-resource-improves-transparency-security-and

Headline: Why metaphor may dictate your security strategy

Source Cisco Talos Blog

Published Thu, 06 Aug 2026 18:00:01 GMT

Key Takeaway In this week's newsletter, Martin looks at how the metaphors we use to describe AI "escaping" its sandbox can completely change how we react to the threat. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.

Summary Engine extractive-rules

Threat Actors Not explicitly stated

Target unknown-target

Technique 待核實

MITRE ATT&CK Unverified

Related CVEs None

Link <https://blog.talosintelligence.com/why-metaphor-may-dictate-your-security-strategy/>

Headline: "Keep going, bro. You've got this!" A data-driven look at how adversaries are weaponizing AI

Source Cisco Talos Blog

Published Tue, 04 Aug 2026 10:00:11 GMT

Key Takeaway Talos has collected prompt logs from threat actor endpoints running various applications, such as Claude Code, CodeX, Cursor, or Gemini. This blog is an analysis of the ways we've seen bad actors leveraging cloud-based AI. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.

Summary Engine extractive-rules

Threat Actors Not explicitly stated

Target cloud/待核實

Technique 待核實

MITRE ATT&CK Unverified

Related CVEs None

Link <https://blog.talosintelligence.com/keep-going-bro-youve-got-this-a-data-driven-look-at-how-adversaries-are-weaponizing-ai/>

Headline: Atlassian Rovo Can Be Tricked Into Sending Jira and Confluence Data to Attackers

Source	The Hacker News
Published	Sat, 08 Aug 2026 14:24:50 +0530
Key Takeaway	Attacker-controlled instructions can make Atlassian's Rovo assistant collect Jira or Confluence data that a signed-in user can access, then send it to an outside server. Two security firms found that behavior independently, by different routes. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://thehackernews.com/2026/08/atlassian-rovo-can-be-tricked-into.html

Headline: New CSS Attacks Can Break Webmail Defenses to Steal Passwords and Tokens

Source	The Hacker News
Published	Sat, 08 Aug 2026 13:33:57 +0530
Key Takeaway	Across attack chains spanning Outlook, Gmail, Fastmail, Proton Mail, Yahoo Mail, and AOL Mail, the techniques can capture passwords, take over third-party accounts, leak tokens, hijack trusted UI actions, and manipulate AI tools that read email. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	defense/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://thehackernews.com/2026/08/new-css-attacks-can-break-webmail.html

Headline: Critical One-Click Vulnerability in Atlassian’s Rovo AI Exposed Enterprise Data

Source	SecurityWeek
Published	Sat, 08 Aug 2026 11:30:00 +0000
Key Takeaway	The RovoBlast attack method identified by Varonis researchers could have been exploited to steal Confluence, Jira and SharePoint data. The post Critical One-Click Vulnerability in Atlassian’s Rovo AI Exposed Enterprise Data appeared first on SecurityWeek . Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	Exploit Chain
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.securityweek.com/critical-one-click-vulnerability-in-atlassians-rovo-ai-exposed-enterprise-data/

Headline: In Other News: AI Slop Limits Apple Bounties, North Carolina Port Attacks, Hackers Target Wall Street

Source	SecurityWeek
Published	Fri, 07 Aug 2026 14:26:42 +0000
Key Takeaway	Noteworthy stories that might have slipped under the radar: ban on Chinese data center tech, QuickFox VPN supply chain attack, IEH Corporation mailbox breached via phishing. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/待核實
Technique	Phishing
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.securityweek.com/in-other-news-ai-slop-limits-apple-bounties-north-carolina-port-attacks-hackers-target-wall-street/

Headline: Hackers breach TrueConf to trojanize client installers with backdoors

Source BleepingComputer

Published Sat, 08 Aug 2026 10:16:23 -0400

Key Takeaway The Head Mare hacktivist group has been exploiting vulnerabilities in unpatched TrueConf video conferencing servers to replace client installers with malicious versions that deliver backdoors.
Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.

Summary Engine extractive-rules

Threat Actors Not explicitly stated

Target unknown-target

Technique Exploit Chain

MITRE ATT&CK Unverified

Related CVEs None

Link <https://www.bleepingcomputer.com/news/security/hackers-breach-trueconf-to-trojanize-client-installers-with-backdoors/>

Headline: Metabase SQLi zero-day exploited in customer data-theft attacks

Source	BleepingComputer
Published	Fri, 07 Aug 2026 16:14:46 -0400
Key Takeaway	A critical Metabase SQL injection vulnerability was exploited in zero-day attacks to breach customer instances in data theft attacks, known to impact Framework and Tally. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	Exploit Chain
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.bleepingcomputer.com/news/security/framework-tally-disclose-metabase-data-theft-attacks/



Sources (official/authoritative first)

<https://www.cisa.gov/known-exploited-vulnerabilities-catalog>

<https://nvd.nist.gov/>

<https://www.cve.org/>

<https://attack.mitre.org/>

[**https://www.microsoft.com/en-us/security/blog/**](https://www.microsoft.com/en-us/security/blog/)

[**https://www.cisa.gov/news-events/cybersecurity-advisories**](https://www.cisa.gov/news-events/cybersecurity-advisories)

[**https://www.mandiant.com/resources**](https://www.mandiant.com/resources)

[**https://blog.talosintelligence.com/**](https://blog.talosintelligence.com/)